

Cirque Corporation

Secure System Acquisition, Development and Maintenance Policy

Generated: January 12, 2026

IS-CIRQ-P-012-G: Secure System Acquisition, Development and Maintenance Policy

Document: IS-CIRQ-P-012-G

Standards Name: Secure System Acquisition, Development and Maintenance Policy

Category: IT Security Related

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: Executive Committee

1. Purpose

The purpose of this policy is to establish Cirque Corporation's requirements for incorporating information security into the entire lifecycle of its information systems and applications, from acquisition and development through operation and maintenance. This policy aims to minimize security vulnerabilities in systems and software, protect intellectual property (e.g., ASIC designs, firmware, source code), and ensure that security is an integral part of all system-related activities, in accordance with ISO/IEC 27001:2022 Annex A.8.25, A.8.28, and A.8.29.

2. Scope

This policy applies to all Cirque Corporation personnel (employees, contractors) involved in the acquisition, development, testing, implementation, and maintenance of all information systems, software applications (including in-house developed, commercial off-the-shelf - COTS, and cloud-based applications), and infrastructure components. This includes specific applications like Cadence (for ASIC design), GitLab (for source code management), Omnify, Asana, QuickBooks, and Microsoft 365 services.

3. Principles of Secure System Lifecycle

Cirque Corporation integrates security into its system lifecycle based on the following principles:

Security by Design: Security considerations shall be embedded at every stage of the system lifecycle, from initial concept and requirements gathering through design, development, testing, deployment, and decommissioning.

Secure Development Practices: Development practices shall adhere to secure coding standards and principles to minimize vulnerabilities in software and systems.

Testing and Validation: All systems and software shall undergo thorough security testing before deployment or significant changes to identify and remediate vulnerabilities.

Supply Chain Security: Security requirements shall be specified and enforced for third-party acquired software, services, and components.

Continuous Improvement: Security processes related to system acquisition, development, and maintenance shall be continuously reviewed and improved.

4. Secure System Acquisition and Development Requirements

4.1. Information Security Requirements Specification: a. Information security requirements shall be identified and documented at the initial stages of any new system acquisition or development project. b. These requirements shall address confidentiality, integrity, availability, accountability, and compliance obligations. c. Specific security requirements shall be defined for sensitive IP such as ASIC designs and firmware developed using tools like Cadence and managed in GitLab.

4.2. Secure Development Environment: a. Development environments shall be logically and, where necessary, physically separated from production environments. b. Access to development and testing environments shall be strictly controlled, based on the principle of least privilege. c. Production data shall not be used in development or test environments unless it has been adequately anonymized or sanitized. d. Development tools (e.g., GitLab, Cadence) shall be securely configured and regularly updated.

4.3. Secure Coding and Development Practices: a. Developers shall adhere to secure coding standards and guidelines (e.g., OWASP Top 10 for web applications, specific guidelines for hardware/firmware development). b. Code reviews shall incorporate security vulnerability checks. c. Use of open-source software and third-party components shall be managed to assess and mitigate associated security risks.

4.4. Security in Development Processes (e.g., GitLab): a. All source code, including firmware and ASIC design files, managed in GitLab shall be subject to version control. b. Access to sensitive repositories in GitLab shall be restricted to authorized developers on a need-to-know basis. c. Automated security scanning tools (e.g., Static Application Security Testing - SAST, Dynamic Application Security Testing - DAST) shall be integrated into the Continuous Integration/Continuous Delivery (CI/CD) pipeline where applicable.

4.5. Acquired Software Security: a. Prior to acquiring or adopting commercial off-the-shelf (COTS) software or cloud services, security due diligence shall be performed to assess inherent risks and vendor security posture. b. Contractual agreements with software vendors

and cloud service providers shall include clear information security clauses. c. Default security settings of acquired software shall be hardened before deployment.

5. System Testing and Acceptance Requirements

5.1. Security Testing: a. All new systems, applications, and significant changes shall undergo comprehensive security testing before being moved to production. This includes: * Vulnerability scanning. * Penetration testing (internal and/or external) for critical systems. * Code reviews. * Functional security testing. b. Testing shall verify that all identified security requirements are met and that no new vulnerabilities have been introduced.

5.2. Acceptance Criteria: a. Systems and applications shall only be accepted into the production environment after demonstrating that they meet predefined security requirements and have successfully passed all security tests. b. Any identified vulnerabilities must be remediated or formally accepted with a clear mitigation plan.

6. System Maintenance and Support

6.1. Vulnerability Management: a. A systematic process shall be in place to identify, assess, and remediate technical vulnerabilities in all operational systems and applications. b. Regular vulnerability scans and penetration tests shall be performed (as per IS-CIRQ-PR-XXX-G: Vulnerability Management Procedure - future document). c. Patches and updates shall be applied in a timely manner as per the IS-CIRQ-PR-013-G: Change Management Procedure.

6.2. System Monitoring: a. Operational systems shall be continuously monitored for security events, anomalies, and potential intrusions, as per IS-CIRQ-PR-015-G: Logging and Monitoring Procedure.

6.3. Information System Audit Controls: a. Audit logs shall be maintained to record system activities and user actions, facilitating accountability and incident investigation.

7. Responsibilities

IT Manager: Overall responsible for the implementation and enforcement of this policy. Oversees the security of development environments and processes.

Development Teams: Responsible for implementing secure coding practices, conducting security reviews, and ensuring security requirements are met during development.

Project Managers: Responsible for ensuring security is integrated into project plans and budgets for system acquisition and development.

System Administrators: Responsible for securely configuring, maintaining, and patching operational systems.

8. Related Documents

IS-CIRQ-PR-017-G: Secure Development Procedure (To be drafted next)

IS-CIRQ-PR-018-G: System Testing and Acceptance Procedure (To be drafted next)

IS-CIRQ-P-011-G: Operations Security Policy

IS-CIRQ-PR-013-G: Change Management Procedure

IS-CIRQ-PR-015-G: Logging and Monitoring Procedure

IS-CIRQ-P-007-G: Asset Management Policy

IS-CIRQ-P-009-G: Cryptography Policy

IS-CIRQ-P-008-G: Access Control Policy

9. Policy Review

This policy will be reviewed at least annually, or sooner if significant changes occur to Cirque Corporation's system development methodologies, technology stack, or the threat landscape.